TRƯỜNG ĐẠI HỌC FPT
NGÀNH AN TOÀN THÔNG TIN
Môn học: PWD301 — Phát triển Web bằng Python

BÁO CÁO ĐỒ ÁN MÔN HỌC

GETAPPS

Nền tảng mạng xã hội chia sẻ và khám phá trải nghiệm du lịch

Nhóm 3

Bảng phân công thành viên

STT	Họ và tên	MSSV	Vai trò / Phụ trách
1	Võ Quốc Khánh	SE203038	Nhóm trưởng — Backend & Frontend; Quản trị Admin, Phân quyền truy cập (RBAC / Broken Access Control)
2	Vũ Hoàng Tuấn	SE201607	Backend; Phòng chống SQL Injection, chuẩn hóa đầu vào
3	Phạm Đồng Thanh Trúc	SE201580	Backend; Phòng chống XSS, thiết lập Content Security Policy
4	Nguyễn Thị Kiều Vy	SE205080	Thiết kế giao diện (UI/UX Design)
5	Nguyễn Tấn Phát	SE173285	Frontend; Rate Limiting chống DDoS/Brute-force, Trang theo dõi bảo mật

1. Giới thiệu đề bài môn học

Đề bài của môn PWD301 Phát triển Web bằng Python yêu cầu mỗi nhóm xây dựng một ứng dụng web hoàn chỉnh bằng Python/Flask, áp dụng các kiến thức về lập trình web, cơ sở dữ liệu quan hệ, xác thực người dùng và triển khai thực tế. Nhóm chọn đề tài gốc Topic 10 — Mạng xã hội chia sẻ ảnh (Photo Sharing Social Network) và mở rộng thành một mạng xã hội chuyên về du lịch, nơi người dùng đăng tải hình ảnh/video, chia sẻ lịch trình chuyến đi, tương tác (thích, bình luận, chia sẻ) và khám phá địa điểm từ cộng đồng. Hướng mở rộng này đã được nhóm đề xuất và tiến hành phát triển trong suốt quá trình làm đồ án.

Ở giai đoạn sau của môn học, giảng viên bổ sung thêm yêu cầu về bảo mật ứng dụng: xây dựng trang quản trị (Admin Panel) với phân quyền người dùng/quản trị viên riêng biệt, bảo vệ cơ sở dữ liệu, thực hiện quy trình kiểm thử xâm nhập (pentest) có ghi nhận và vá lỗi, cùng với việc phòng chống ba dạng tấn công phổ biến là SQL Injection, Cross-Site Scripting (XSS) và DDoS/Brute-force, mỗi dạng có kịch bản minh chứng (demo) kèm theo. Nội dung báo cáo này trình bày đầy đủ kết quả nhóm đã thực hiện theo đề bài nói trên.

2. Giới thiệu nhóm và dự án GetApps

2.1. Giới thiệu nhóm

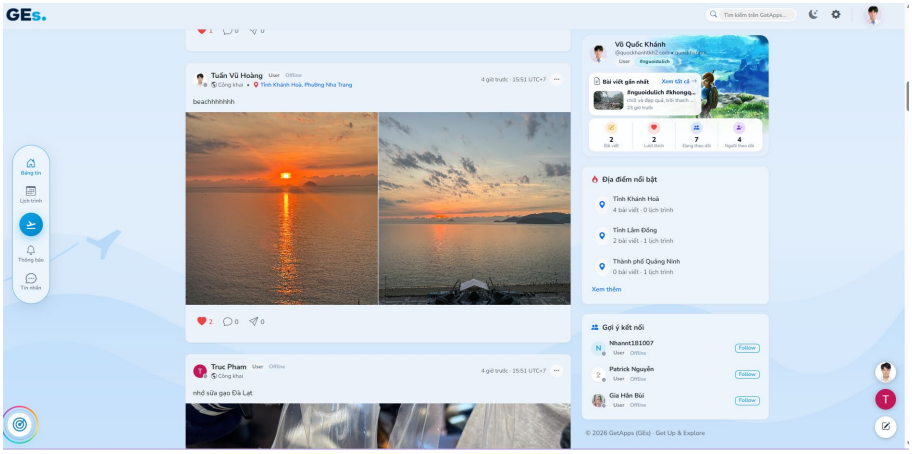
Nhóm gồm 5 thành viên như bảng phân công ở trang bìa, do Võ Quốc Khánh làm trưởng nhóm. Công việc được chia theo hai mảng song song trong suốt quá trình phát triển:

- Thiết kế giao diện (UI/UX): Nguyễn Thị Kiều Vy.
- Backend (xử lý nghiệp vụ, cơ sở dữ liệu, API): chia đều cho Võ Quốc Khánh, Phạm Đồng Thanh Trúc và Vũ Hoàng Tuấn.
- Frontend (giao diện, tương tác người dùng): Võ Quốc Khánh và Nguyễn Tấn Phát.

Ở giai đoạn bảo mật, mỗi thành viên phụ trách một mảng riêng: Khánh — Admin Panel & phân quyền (Broken Access Control); Tuấn — chống SQL Injection; Trúc — chống XSS; Phát — chống DDoS/Brute-force bằng Rate Limiting và xây dựng trang theo dõi bảo mật.

2.2. Giới thiệu dự án GetApps

GetApps với khẩu hiệu "Get Up & Explore" là một mạng xã hội tập trung vào du lịch, cho phép người dùng đăng bài viết (ảnh/video kèm caption, hashtag, địa điểm) và đăng lịch trình chuyến đi chi tiết (theo ngày, theo chặng, kèm nơi lưu trú), sau đó tương tác với nhau qua thích, bình luận, chia sẻ, theo dõi (follow) và nhắn tin trực tiếp. Mục tiêu của dự án là tạo ra một nơi để người đi du lịch chia sẻ trải nghiệm thực tế và tìm cảm hứng cho chuyến đi tiếp theo từ chính cộng đồng, thay vì chỉ xem thông tin một chiều từ các trang review.



3. Công cụ, công nghệ và chuẩn sử dụng

3.1. Công nghệ backend

- Ngôn ngữ: Python; Framework: Flask, tổ chức theo mô hình Application Factory, chia nhỏ ứng dụng thành các Blueprint độc lập: auth (xác thực, hồ sơ, tìm kiếm), locations (bài viết, bảng tin), plans (lịch trình), chat (tin nhắn), ges_around (gợi ý địa điểm), admin (quản trị), api.
- Cơ sở dữ liệu: SQLite, truy xuất qua SQLAlchemy ORM; quản lý thay đổi cấu trúc bảng (schema) bằng Flask-Migrate (Alembic).
- Xác thực: Flask-Login quản lý phiên đăng nhập (session cookie); mật khẩu băm bằng hàm generate_password_hash của Werkzeug (không lưu mật khẩu dạng thuần); hỗ trợ đăng nhập bằng tài khoản Google (OAuth 2.0).
- Bảo vệ form: Flask-WTF kèm CSRF token cho các form có thao tác ghi dữ liệu (ví dụ upload bài viết).
- Chống truy cập dồn dập: Flask-Limiter (phiên bản 4.1.1), chiến lược giới hạn "moving window" (cửa sổ trượt).

3.2. Công nghệ frontend

- Template engine: Jinja2 (tự động escape ký tự HTML — một lớp phòng chống XSS mặc định).
- Giao diện: Bootstrap 5 và Bootstrap Icons, dựng responsive cho cả desktop và di động.
- Tương tác không tải lại trang: JavaScript thuần kết hợp AJAX (Fetch API) gọi các API JSON của backend.

3.3. Triển khai & kiểm thử

- Đóng gói và chạy ứng dụng bằng Docker và Docker Compose; máy chủ ứng dụng WSGI: Gunicorn.
- Kiểm thử tự động: pytest, với bộ 135 test case bao phủ các module chính (chi tiết ở Mục 12).

3.4. Chuẩn và nguyên tắc bảo mật áp dụng

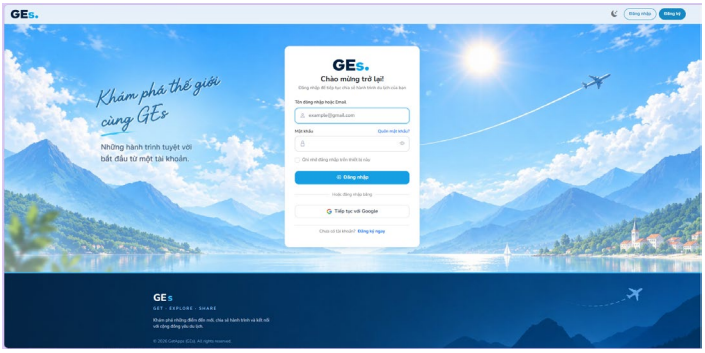
Nhóm bám theo các khuyến nghị của OWASP (Open Web Application Security Project) — tổ chức phi lợi nhuận chuyên về bảo mật ứng dụng web — trong các điểm sau:

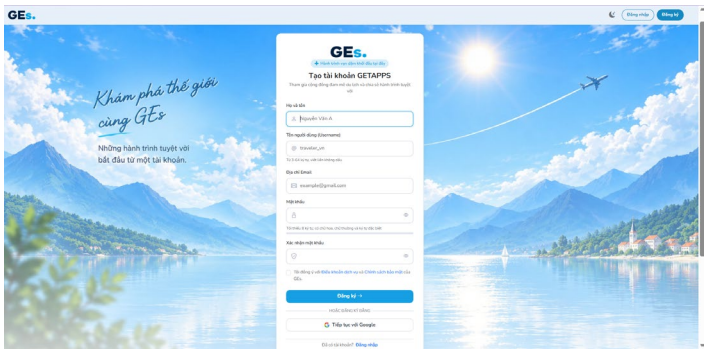
- Chống SQL Injection: toàn bộ truy vấn CSDL đi qua SQLAlchemy ORM, dữ liệu người dùng luôn được xử lý như tham số (parameterized query), không nối chuỗi SQL thủ công.
- Chống XSS: tận dụng cơ chế autoescape của Jinja2 ở phía server, kết hợp hàm escapeHtml() ở phía client cho nội dung dựng động bằng JavaScript (ví dụ bình luận).
- Chống giả mạo yêu cầu (CSRF): CSRF token qua Flask-WTF.
- Chống Brute-force/DDoS ở tầng ứng dụng: giới hạn tần suất request theo từng endpoint nhạy cảm bằng Flask-Limiter (Rate Limiting).
- Kiểm soát truy cập (Access Control): phân quyền Admin/User (RBAC) ở trang quản trị; kiểm tra quyền xem nội dung riêng tư ở từng bài viết/lịch trình.
- Kiến trúc: tổ chức theo Blueprint (tương tự mô hình MVC) giúp tách biệt từng nghiệp vụ; các API nội bộ phục vụ AJAX trả JSON theo phong cách RESTful.

4. Hướng dẫn sử dụng và các chức năng chính

4.1. Đăng ký / Đăng nhập

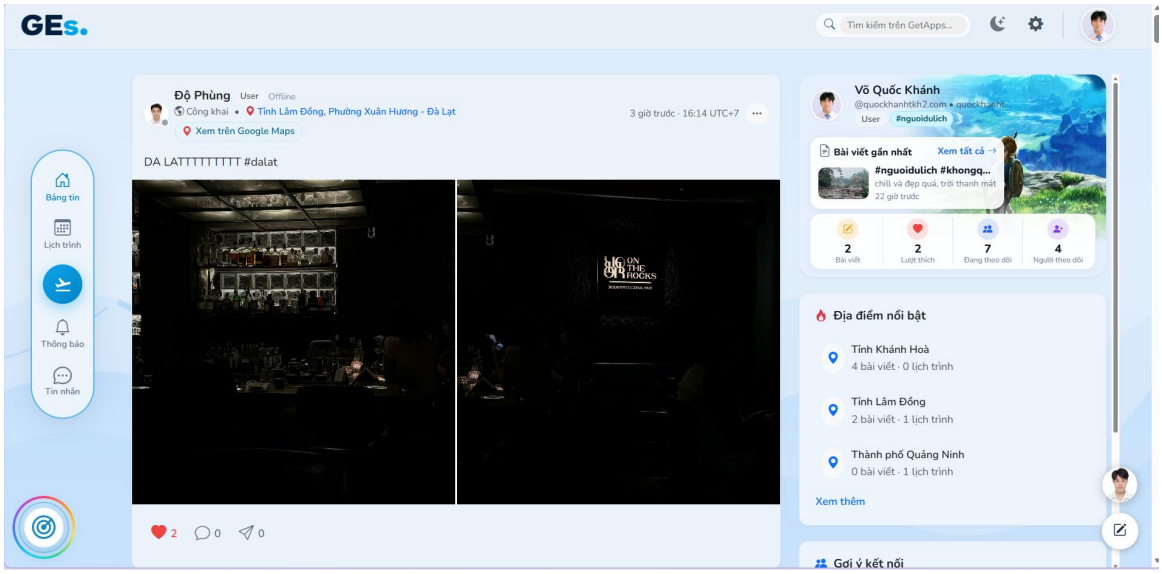
Người dùng đăng ký bằng tên đăng nhập, email và mật khẩu (yêu cầu tối thiểu 8 ký tự, có cả chữ và số), hoặc đăng nhập nhanh bằng tài khoản Google. Khách truy cập (chưa đăng nhập) vẫn xem được Bảng tin, chi tiết bài viết công khai và sử dụng được chức năng tìm kiếm — chỉ khi thực hiện một hành động cần tài khoản (thích, bình luận, lưu, đăng bài, nhắn tin, theo dõi...) hệ thống mới yêu cầu đăng nhập, nhằm tăng khả năng khám phá nội dung cho người mới.





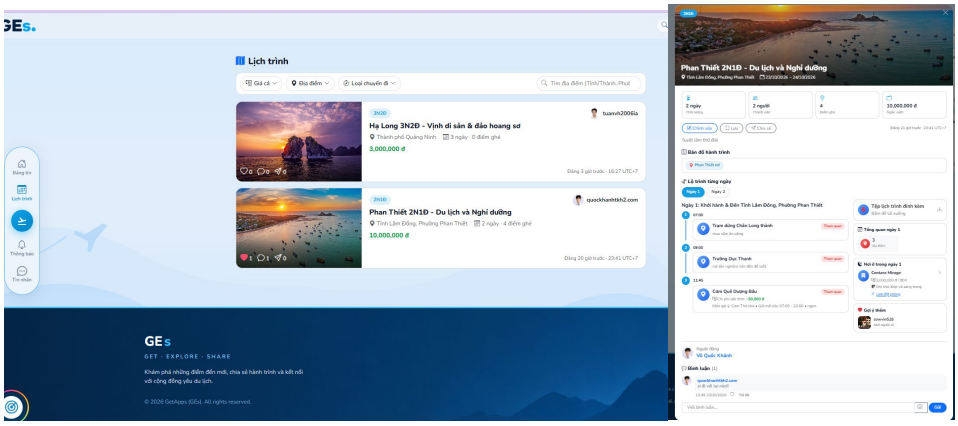
4.2. Bảng tin (Feed)

Tại /locations/feed, Bảng tin hiển thị tất cả bài viết ở chế độ Công khai theo kiểu khám phá (Discovery) — không giới hạn chỉ bài của người đang theo dõi. Mỗi thẻ bài viết gồm: avatar và tên người đăng, ảnh/video, caption, hashtag, địa điểm (hiển thị dưới dạng chip bấm mở Google Maps ở tab mới), số lượt thích/bình luận, cùng trạng thái đã thích/đã lưu của người xem hiện tại.



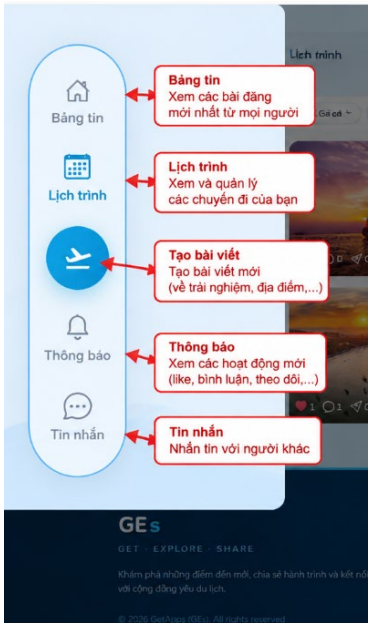
4.3. Tab Lịch trình

Tại /plans, trang hiển thị các lịch trình du lịch ở chế độ Công khai do cộng đồng đăng, trình bày dưới dạng thẻ có ảnh bìa tỉ lệ 16:9 kèm thông tin tổng quan chuyến đi (điểm đến, thời gian, dạng chuyến đi). Lịch trình cũng hỗ trợ thích, bình luận, chia sẻ như bài viết thông thường.



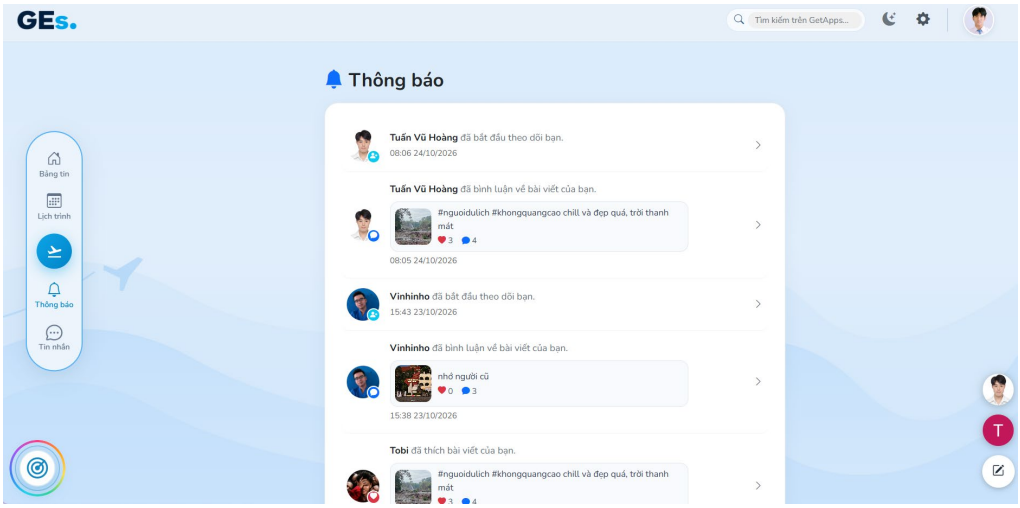
4.4. Nút Đăng (biểu tượng máy bay giấy)

Nút đăng ở giữa thanh điều hướng mở ra lựa chọn giữa Đăng bài viết và Đăng lịch trình, dẫn người dùng sang đúng biểu mẫu tương ứng (chi tiết nội dung từng loại ở Mục 5 và Mục 6).



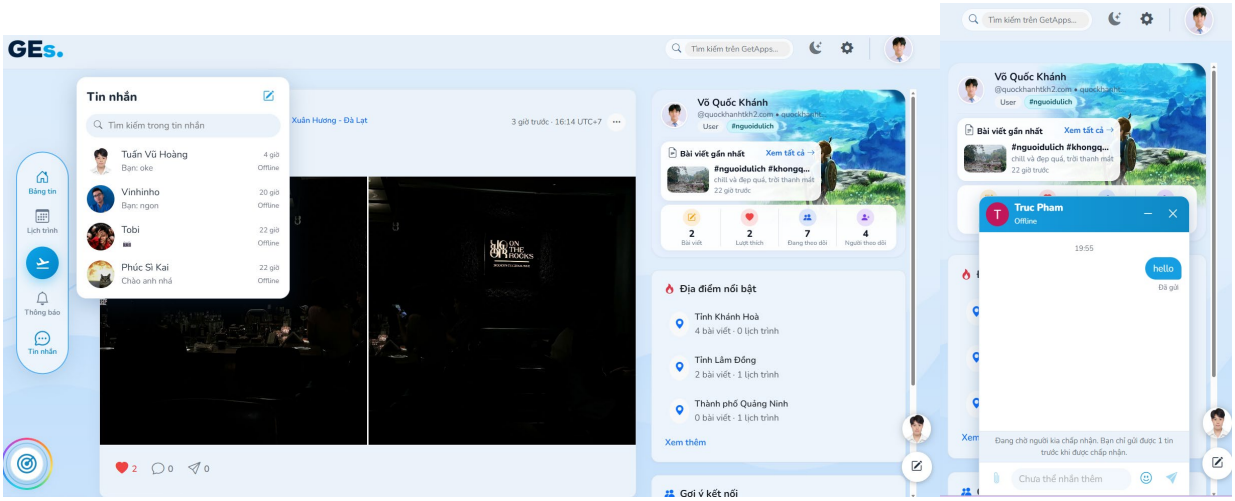
4.5. Chuông thông báo

Hệ thống thông báo (model Notification) báo các sự kiện: có người thích/bình luận bài, có người đăng lại (repost) bài của mình, có người theo dõi mình, được nhắc tên (mention), và các thông báo kiểm duyệt từ quản trị viên khi bài/lịch trình bị ẩn hoặc gỡ do nghi vi phạm. Hệ thống không tự thông báo cho chính chủ bài khi họ tự tương tác với bài của mình, và không tạo thông báo trùng lặp nếu thông báo cùng loại trước đó chưa được đọc.



4.6. Tin nhắn

Tại /chat, người dùng xem danh sách cuộc trò chuyện, gửi/nhận tin nhắn, đánh dấu đã đọc, thả tim (reaction) cho tin nhắn, xóa tin nhắn đã gửi, kèm hiển thị trạng thái đang hoạt động/ngoại tuyến (presence) của người đối thoại.



4.7. Thích, bình luận, chia sẻ, lưu bài

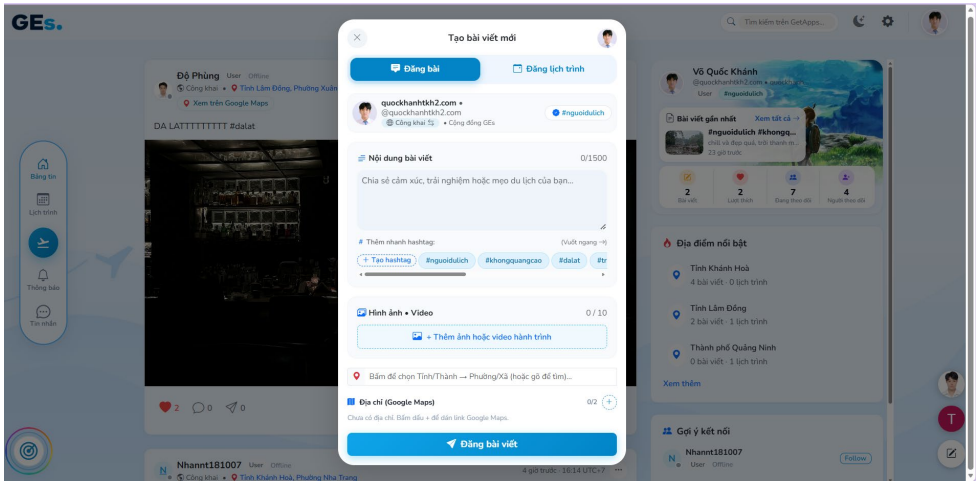
- Thích (Like): bật/tắt (toggle), áp dụng cho cả bài viết và lịch trình.
- Bình luận (Comment): tạo, xem danh sách, tự xóa bình luận của chính mình.
- Chia sẻ (Share): mở ra 3 lựa chọn — Tải về máy, Đăng lại (Repost, có thể kèm ghi chú tối đa 500 ký tự và chọn lại chế độ Công khai/Riêng tư), Sao chép liên kết.
- Lưu bài (Save): bật/tắt, chống lưu trùng.

Toàn bộ các hành động trên đều kiểm tra quyền xem bài trước khi cho tương tác — bài ở chế độ Riêng tư chỉ người có quyền (chủ bài hoặc người được phép xem theo thiết lập) mới thao tác được.

5. Đăng bài viết

Khi đăng một bài viết, người dùng cung cấp:

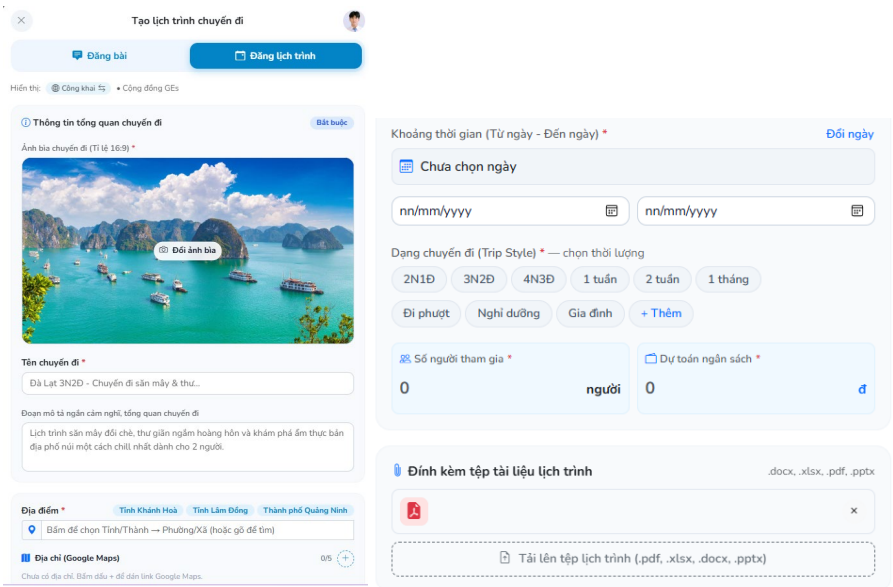
- Ảnh và/hoặc video minh họa.
- Caption (nội dung mô tả).
- Hashtag tự do, tối đa 3 hashtag mỗi bài, mỗi hashtag tối đa 30 ký tự (hệ thống tự chuẩn hóa: bỏ dấu, viết thường, chỉ giữ chữ/số/gạch dưới).
- Chế độ hiển thị: Công khai hoặc Riêng tư.
- Địa điểm: một địa điểm chính và có thể thêm địa điểm phụ, chọn qua ô tự động gợi ý (autocomplete) dựa trên dữ liệu địa danh đã có.



6. Đăng lịch trình

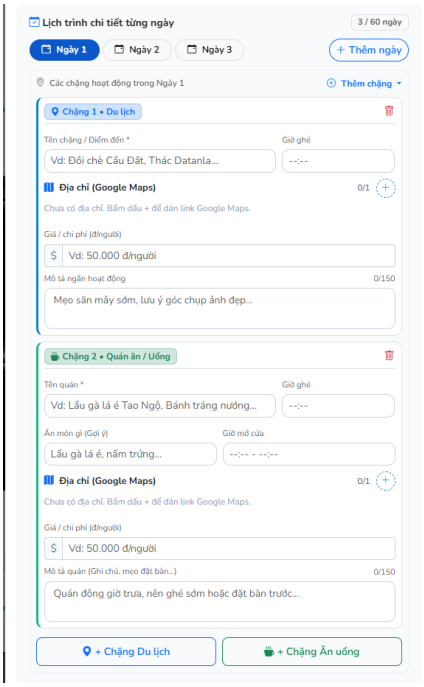
6.1. Thông tin tổng quan chuyến đi

- Ảnh bìa chuyến đi (tỉ lệ 16:9).
- Tên chuyến đi, đoạn mô tả/cảm nghĩ tổng quan.
- Địa điểm chính (destination) — chọn Tỉnh/Thành rồi Phường/Xã, hoặc gõ để tìm.
- Khoảng thời gian: ngày bắt đầu — ngày kết thúc.
- Dạng chuyến đi (trip style): các lựa chọn có sẵn (ví dụ 2N1Đ, 3N2Đ...) hoặc tự thêm.
- Số người tham gia, dự toán ngân sách.
- File đính kèm lịch trình chi tiết (ví dụ .docx/.xlsx/.pdf...), có thể đính kèm nhiều file.



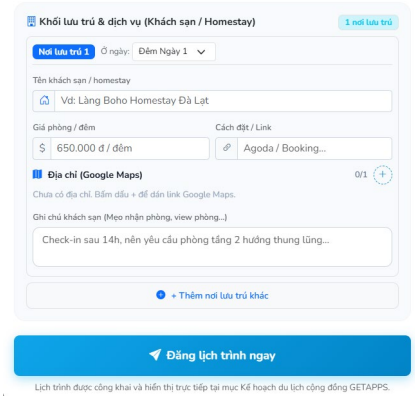
6.2. Chi tiết từng ngày và từng chặng

Người dùng thêm từng ngày (có thể ghi chú ngày, quãng đường di chuyển ước tính, tổng thời gian dự kiến trong ngày), trong mỗi ngày thêm nhiều chặng hoạt động gồm: tên hoạt động, địa chỉ/link địa điểm (Google Maps), khung giờ, giá/chi phí, phương tiện di chuyển, ảnh minh họa và ghi chú. Với chặng thuộc loại ăn uống, có thêm ô món ăn gợi ý và giờ mở cửa quán.



6.3. Nơi lưu trú

Mỗi lịch trình có thể thêm một hoặc nhiều nơi lưu trú (khách sạn/homestay) gồm: tên, địa chỉ, giờ nhận/trả phòng, số khách, giá mỗi đêm, link đặt phòng và ghi chú.

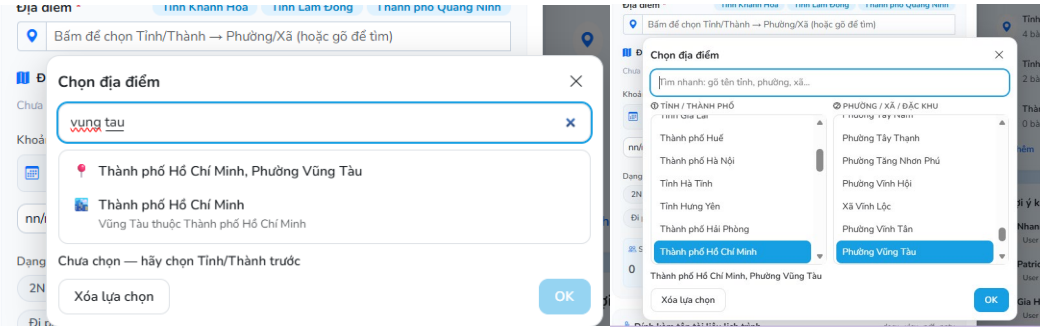


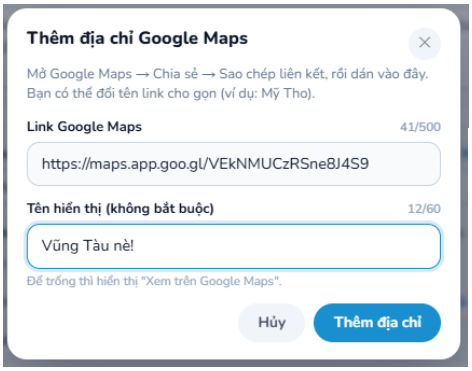
7. Tìm kiếm

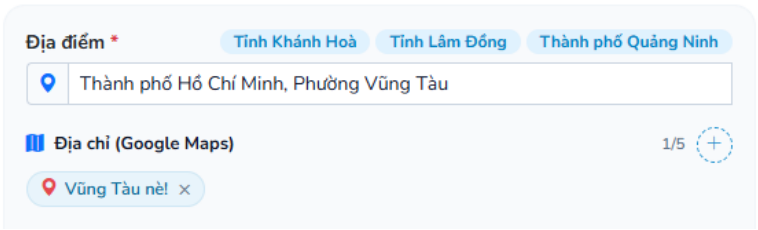
Trang /search hỗ trợ tìm kiếm đa đối tượng cùng lúc — Người dùng, Bài viết, Lịch trình và Địa điểm — tách theo từng tab trên giao diện kết quả. Riêng ở mục tổng hợp ("Tất cả"), bài viết và lịch trình được sắp xếp theo Engagement Score (điểm tương tác), tính từ tổng số lượt thích, bình luận và chia sẻ. Người dùng khớp theo thứ tự ưu tiên: trùng khớp chính xác tên đăng nhập/biệt danh/họ tên trước, sau đó mới đến khớp một phần (bắt đầu bằng từ khóa).

Hệ thống hỗ trợ tìm kiếm tiếng Việt có dấu lẫn không dấu (ví dụ gõ "da lat" vẫn ra "Đà Lạt") nhờ hàm chuẩn hóa chuỗi (bỏ dấu, viết thường) và sinh ra nhiều biến thể của từ khóa để so khớp. Có thêm ô gợi ý tự động (/search/suggest) khi đang gõ.

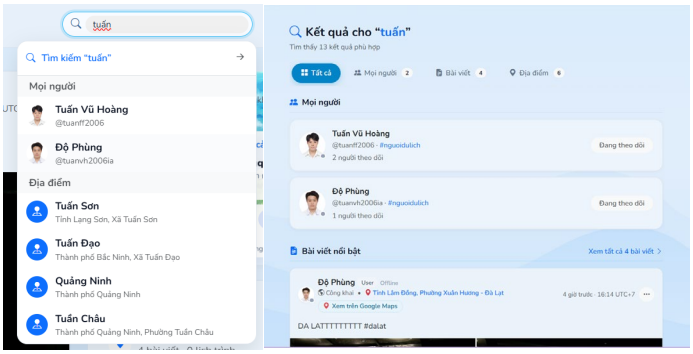
Đối với tìm kiếm địa điểm, hệ thống tra cứu trên 2 nguồn: (1) bộ dữ liệu địa danh hành chính Việt Nam gồm 34 tỉnh/thành và các phường/xã (nguồn dữ liệu ở Mục 10), và (2) các địa điểm người dùng đã lưu trong cơ sở dữ liệu của GetApps.

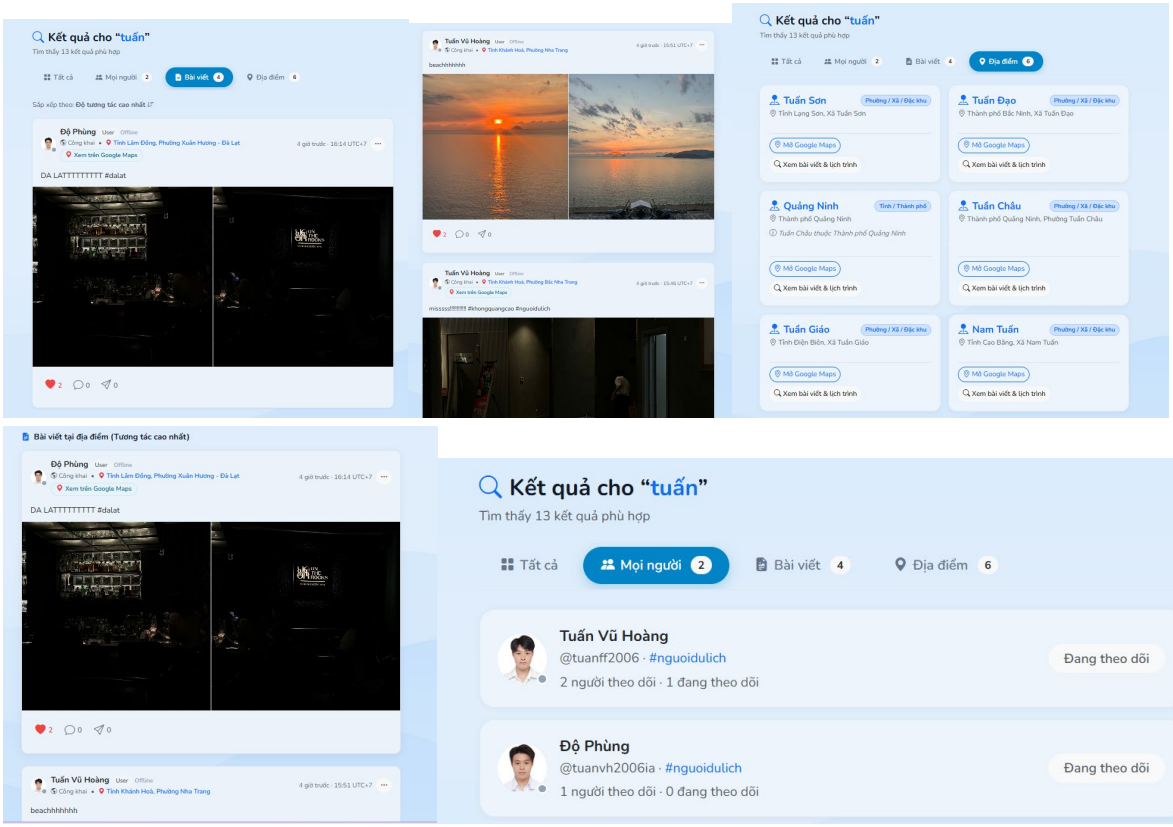






Mỗi lượt tìm kiếm cũng được kiểm tra dấu hiệu SQL Injection ở phía server (chỉ để ghi log theo dõi — bản thân truy vấn đã an toàn nhờ dùng ORM, xem Mục 12) và giới hạn 45 lượt/phút để chống lạm dụng.

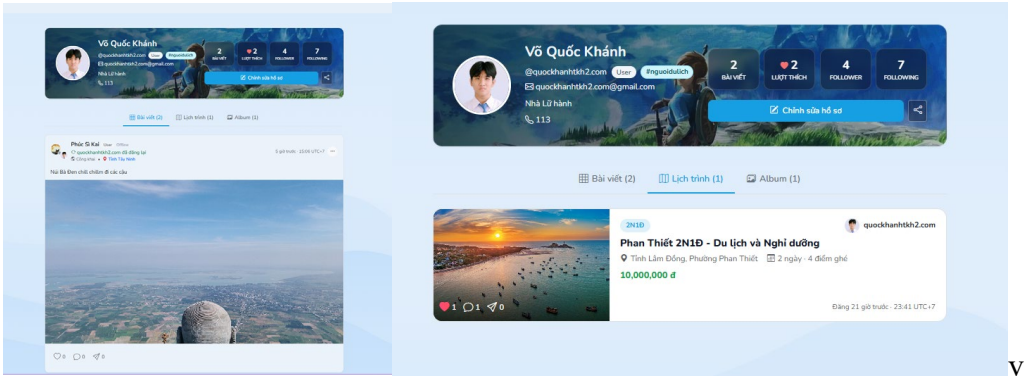




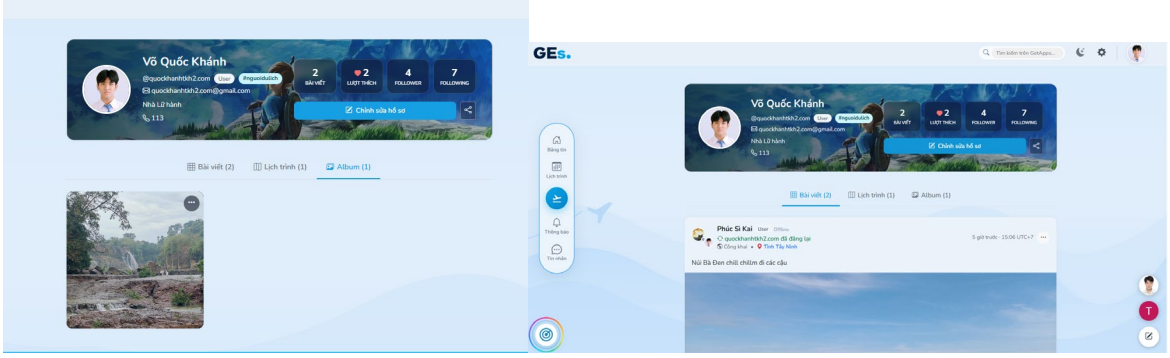
8. Trang cá nhân và Cài đặt

8.1. Trang cá nhân

Trang cá nhân hiển thị ảnh đại diện, ảnh nền trang (nếu đã đặt), biệt danh, tiểu sử, số lượng người theo dõi/đang theo dõi, cùng 3 mục: Tất cả, Bài đăng, Lịch trình. Chủ trang có thể bấm vào từng bài để đổi nhanh chế độ Công khai/Riêng tư ngay tại đây.

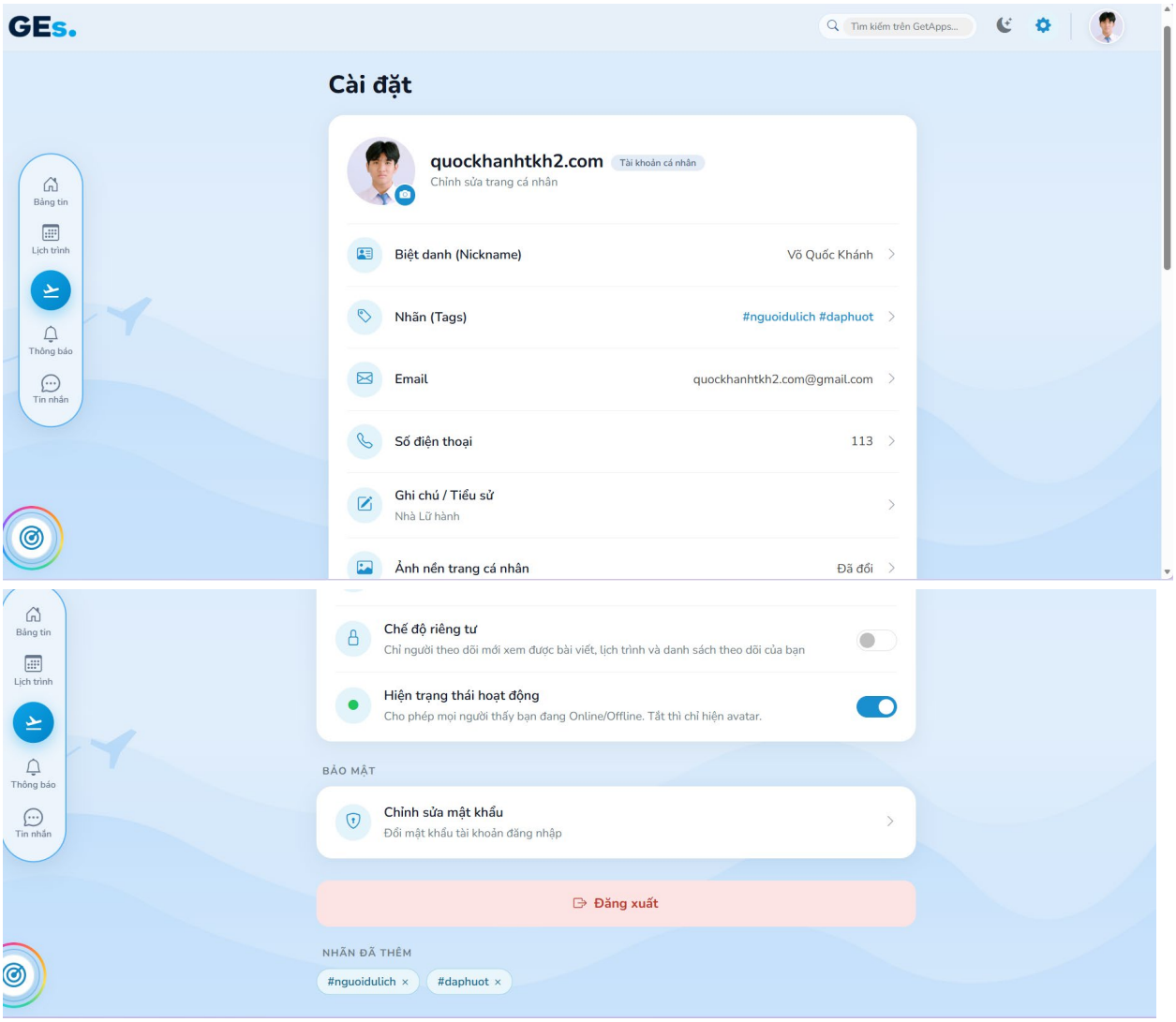


V



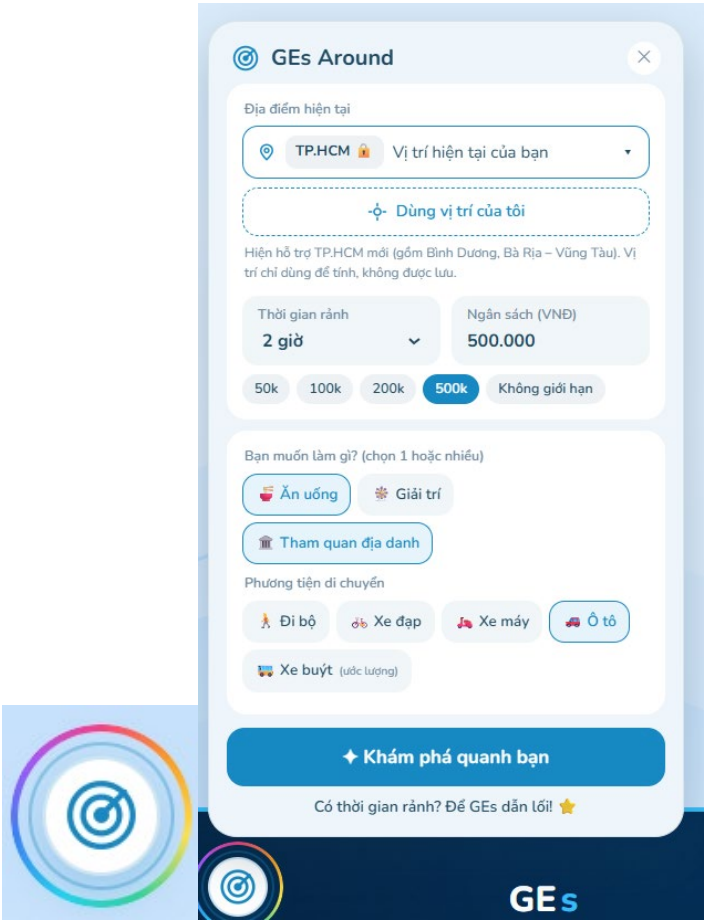
8.2. Cài đặt

Trang Cài đặt cho phép chỉnh: ảnh đại diện, ảnh nền trang cá nhân, biệt danh, nhãn hồ sơ (tag), tiểu sử, số điện thoại, email, và đổi mật khẩu. Ảnh nền trang cá nhân đổi qua API riêng, có nút đưa về lại ảnh nền mặc định; khi đã đặt, ảnh nền phủ kín phần đầu trang cá nhân kèm lớp phủ tối nhẹ để chữ luôn đọc rõ.



9. Chức năng GEs Around

GEs Around là tính năng gợi ý địa điểm ăn uống, giải trí và tham quan quanh khu vực TP. Hồ Chí Minh mới (sau sáp nhập, gồm cả Bình Dương và Bà Rịa – Vũng Tàu cũ), dựa trên vị trí người dùng chọn, thời gian rảnh, phương tiện di chuyển và ngân sách. Người dùng chọn khu vực từ danh sách địa danh TP.HCM có sẵn (thay vì gõ tự do), chọn nhu cầu (ăn uống / giải trí / tham quan), thời gian rảnh và phương tiện, hệ thống trả về danh sách địa điểm phù hợp kèm đường dẫn chỉ đường qua Google Maps.



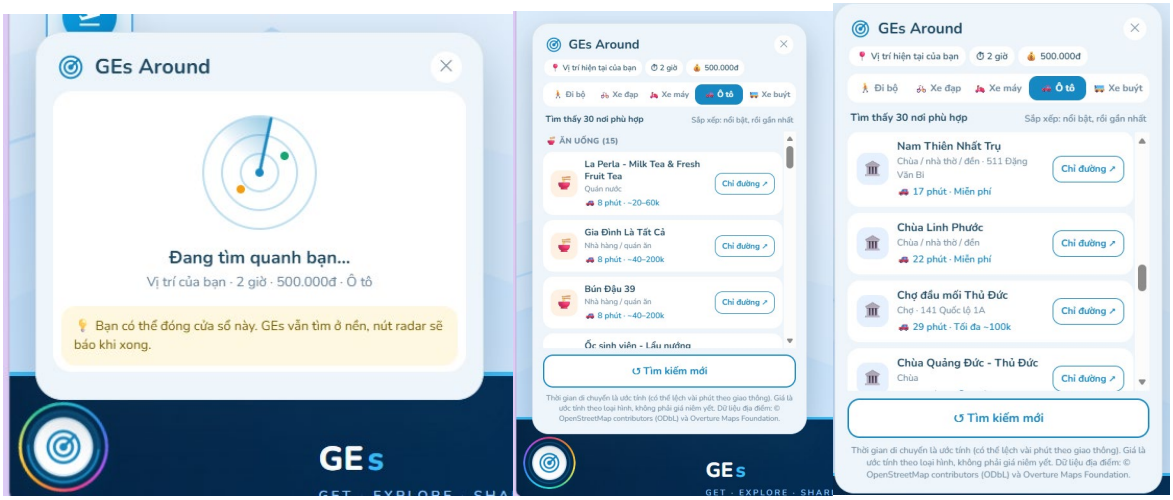
9.1. Thành phần ước lượng thời gian di chuyển (mô hình hồi quy)

Phần tính chất "AI/ML" của tính năng là một mô hình hồi quy tuyến tính bình phương tối thiểu (linear regression), ước lượng thời gian di chuyển theo công thức phút_di_chuyển = a×khoảng_cách + b cho từng loại phương tiện (đi bộ, xe đạp, xe máy, ô tô; riêng xe buýt chưa có dữ liệu đo nên ước lượng gián tiếp từ ô tô, và metro chưa hỗ trợ). Hệ số a, b được hồi quy trên 25 cặp điểm do nhóm tự đo tay trên Google Maps. Vì cỡ mẫu còn nhỏ, nhóm áp dụng thêm hệ số an toàn (nhân 1,10) để nếu có sai số thì thiên về hướng ước lượng dư thời gian hơn là thiếu thời gian.

9.2. Dữ liệu địa điểm GEs Around

Dữ liệu các quán ăn, điểm giải trí và điểm tham quan lấy từ OpenStreetMap — trích xuất bằng osmium từ file địa lý vietnam-261020.osm.pbf — giới hạn trong ranh giới vùng TP.HCM mới. Theo nhật ký trích xuất dữ liệu, tổng cộng có 39.922 địa điểm có tên trên toàn bộ dữ liệu nguồn, trong đó 9.072 địa điểm nằm trong vùng TP.HCM mới được giữ lại, chia theo nhóm: 5.705 địa điểm ăn uống, 2.933 địa điểm tham quan, 434 địa điểm giải trí. Dữ liệu được bổ sung thêm từ Overture Maps Foundation khi cần. Giá tiền hiển thị (khi quán không có giá niêm yết công khai trong dữ liệu nguồn) là mức ước tính theo loại hình, có ghi rõ là "ước tính".

Nguồn: © OpenStreetMap contributors (giấy phép ODbL) và Overture Maps Foundation.



10. Nguồn dữ liệu địa danh hành chính (34 tỉnh/thành)

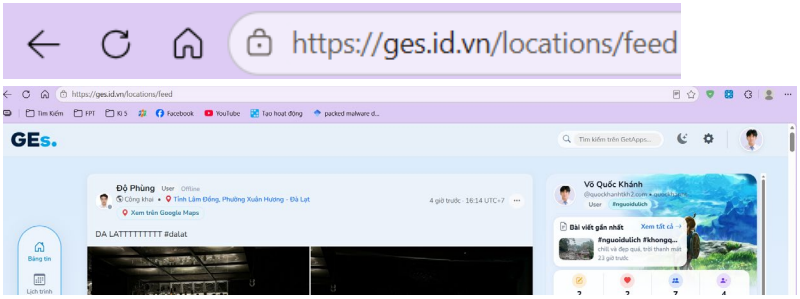
Dữ liệu địa danh hành chính Việt Nam dùng cho chức năng chọn/tìm địa điểm (đăng bài, đăng lịch trình, tìm kiếm) lấy từ bộ dữ liệu mở vietnamese-provinces-database, phiên bản v5.2.0, cập nhật theo Nghị quyết 388/NQ-UBTVQH16 về sắp xếp đơn vị hành chính, gồm 34 tỉnh/thành phố cùng danh sách phường/xã/đặc khu trực thuộc.

Nguồn: https://github.com/thanglequoc/vietnamese-provinces-database (giấy phép MIT).

11. Triển khai Domain và Server

Web GetApps được triển khai chạy 24/7, độc lập với máy cá nhân của thành viên nào trong nhóm, trên một VPS thuê riêng:

- Nhà cung cấp: zcloudviet, gói Cloud Standard, cấu hình 4 vCPU / 4GB RAM / 40GB SSD, hệ điều hành Ubuntu 24.04.
- Đóng gói ứng dụng chạy bằng Docker và Docker Compose, máy chủ ứng dụng Gunicorn; container tự khởi động lại khi gặp sự cố hoặc khi VPS khởi động lại (restart: unless-stopped).
- Dữ liệu (cơ sở dữ liệu SQLite và ảnh người dùng tải lên) được lưu ở ngoài container qua volume mount, không bị mất khi cập nhật/triển khai lại code.
- Domain: ges.id.vn, đăng ký miễn phí qua chương trình tên miền .id.vn.
- Kết nối domain vào server qua Cloudflare Tunnel — không mở cổng dịch vụ web ra Internet trực tiếp; tường lửa UFW trên VPS chỉ cho phép duy nhất cổng SSH.
- Đăng nhập Google OAuth được cấu hình thêm domain production (ges.id.vn) vào danh sách nguồn/redirect URI được phép trên Google Cloud Console.
- Sao lưu cơ sở dữ liệu tự động mỗi ngày (giữ lại bản sao lưu trong 14 ngày gần nhất) để phòng ngừa mất dữ liệu.



12. Kiểm thử backend và trang Quản trị (Admin)

12.1. Kiểm thử tự động (pytest)

Nhóm xây dựng bộ kiểm thử tự động bằng pytest với 135/135 test case PASS (100%), bao phủ các nhóm chức năng: admin, auth, cơ bản (basic), bookmarks, bình luận, cấu hình, frontend, lịch trình (itinerary), địa điểm (locations), thông báo, tìm địa điểm (places), bài viết (posts), rate limiting, tìm kiếm (search, search_feature), người dùng (users).

12.2. Rate Limiting chống DDoS/Brute-force

Áp dụng giới hạn tần suất theo từng endpoint nhạy cảm bằng Flask-Limiter:

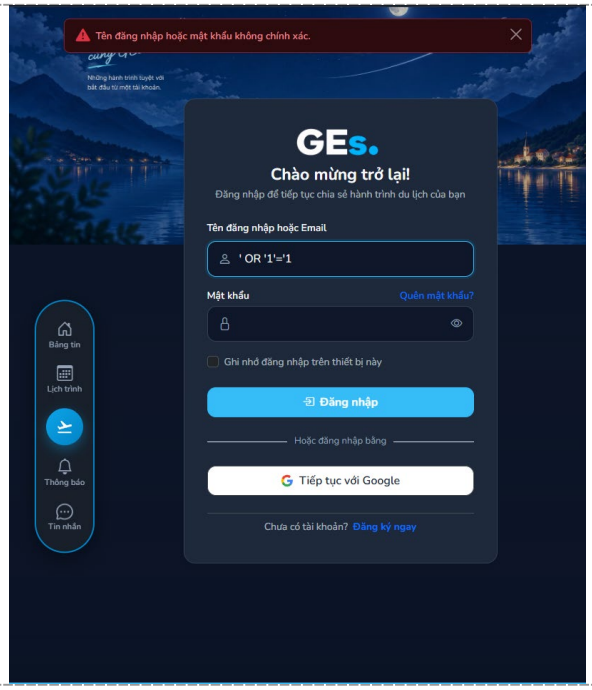
Endpoint	Giới hạn	Mục tiêu bảo vệ
POST /login	5/phút, 20/giờ	Chống dò mật khẩu (brute-force), dò danh sách tài khoản
POST /register	3/phút, 10/giờ	Chống bot đăng ký tài khoản ồ ạt
POST /forgot-password	3/phút	Chống spam yêu cầu đặt lại mật khẩu
POST /resend-otp	3/phút	Chống spam gửi OTP
POST /change-password	5/phút	Chống brute-force đổi mật khẩu
GET /search	30/phút	Chống cào dữ liệu (scraping)
GET /search/suggest	30/phút	Chống làm quá tải truy vấn gợi ý
POST /upload	10/phút	Chống tràn ổ đĩa máy chủ qua upload ảnh

Khi vượt ngưỡng, hệ thống trả mã lỗi HTTP 429: trả JSON cho yêu cầu kiểu API/AJAX, hoặc hiển thị giao diện 429 riêng (kèm đếm ngược thời gian mở khóa) cho người dùng trình duyệt thông thường. Cơ chế được kiểm thử tự động bằng 5 kịch bản riêng trong tests/test_rate_limiting.py, trong đó có mô phỏng 6 lần đăng nhập liên tiếp trong 1 phút để xác nhận hệ thống chặn đúng từ lần thứ 6.

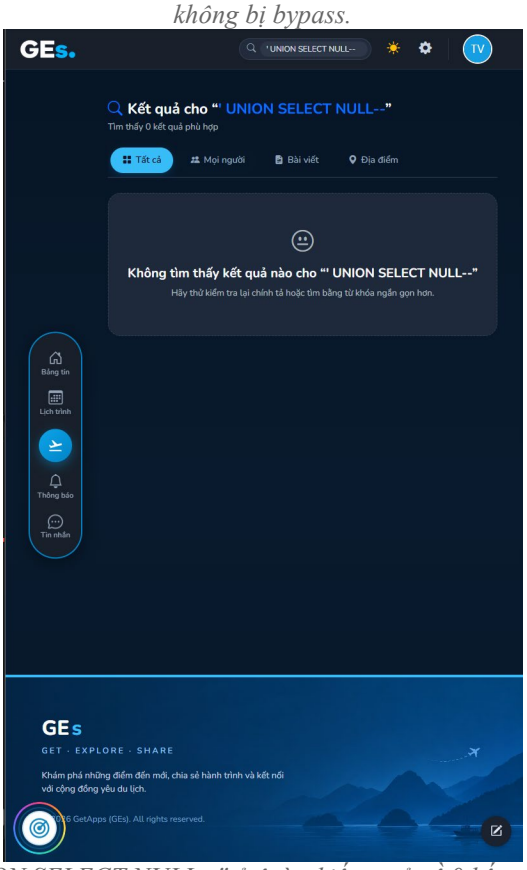
12.3. Kiểm thử SQL Injection

Nhóm thử các dạng payload theo phương pháp kiểm tra chuẩn của OWASP (dấu nháy đơn, điều kiện OR luôn đúng, chèn chú thích SQL, UNION SELECT) trên ô đăng nhập và ô tìm kiếm. Kết quả: tất cả đều an toàn, không bị đăng nhập bypass, không lộ dữ liệu, không phát sinh lỗi hệ thống — vì toàn bộ truy vấn CSDL đi qua SQLAlchemy ORM dưới dạng parameterized query, ký tự

đặc biệt người dùng nhập luôn được xử lý như dữ liệu thuần, không bao giờ bị hiểu thành cú pháp SQL.



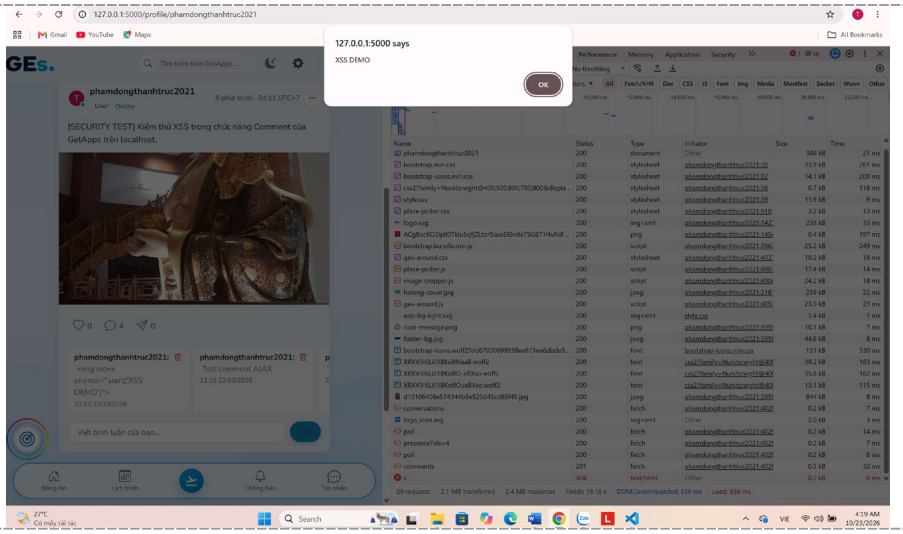
Hình 12.1 — Thử payload " OR luôn đúng" ở ô đăng nhập: hệ thống báo sai tài khoản/mật khẩu như bình thường, không bị bypass.



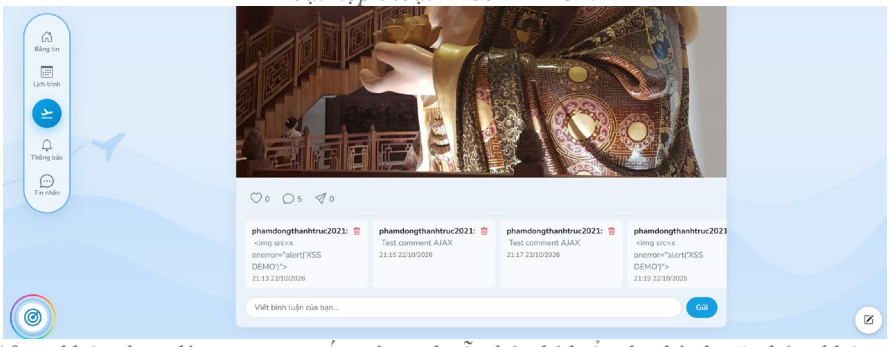
Hình 12.2 — Thử payload "UNION SELECT NULL--" ở ô tìm kiếm: trả về 0 kết quả, không lộ dữ liệu, không lỗi hệ thống.

12.4. Kiểm thử XSS (Cross-Site Scripting)

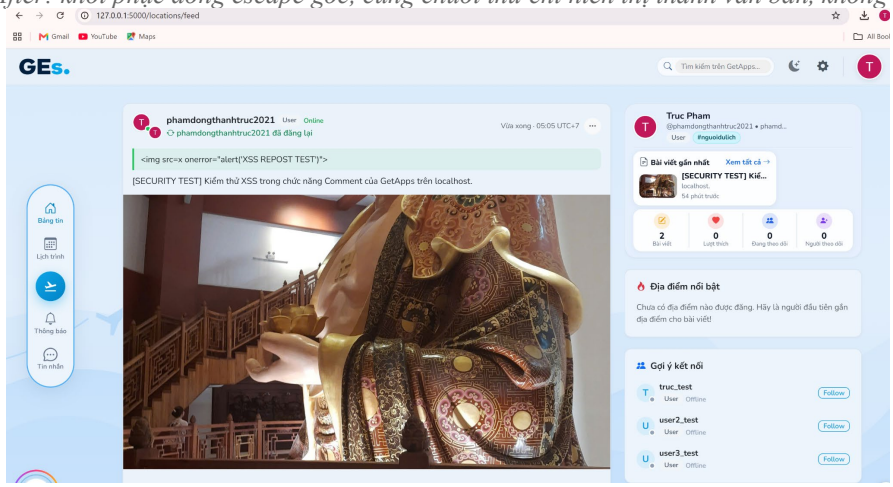
Nhóm thực hiện kiểm thử động theo hai bước tại chức năng Bình luận trên Bảng tin: bước "Before" cố ý sửa tạm một dòng hiển thị để bỏ qua việc escape ký tự HTML, nhập chuỗi thử <img src=x onerror="alert('XSS DEMO')"> vào ô bình luận — kết quả trình duyệt bật hộp thoại cảnh báo, xác nhận lỗ hổng thật sự xảy ra nếu thiếu escape. Bước "After" khôi phục lại đúng dòng code gốc (dùng content_html hoặc hàm escapeHtml()) và lặp lại phép thử — chuỗi hiển thị thành văn bản thuần, không còn thực thi mã. Nhóm cũng kiểm thử bổ sung tính năng Đăng lại (Repost): nhập cùng dạng chuỗi vào ô ghi chú, kết quả ghi chú hiển thị thành văn bản, không bật hộp thoại, khớp với việc nơi hiển thị dùng cú pháp Jinja2 tự động escape. Chức năng Thích (Like) và một số luồng Chia sẻ khác (Sao chép liên kết, Tải về) được rà soát mã nguồn, không phát hiện điểm nhận nội dung văn bản tùy ý của người dùng để hiển thị trực tiếp ra HTML.



Hình 12.3 — Before: dòng render tạm bỏ escape, chuỗi <img src=x onerror=...> trong bình luận làm trình duyệt bật hộp thoại "XSS DEMO".



Hình 12.4 — After: khôi phục dòng escape gốc, cùng chuỗi thử chỉ hiển thị thành văn bản, không còn hộp thoại.



Hình 12.5 — Kiểm thử bổ sung ở Repost: ghi chú chứa chuỗi HTML thử nghiệm hiển thị nguyên văn dạng văn bản trên Bảng tin, không thực thi mã.

12.5. Trang Quản trị (Admin Panel)

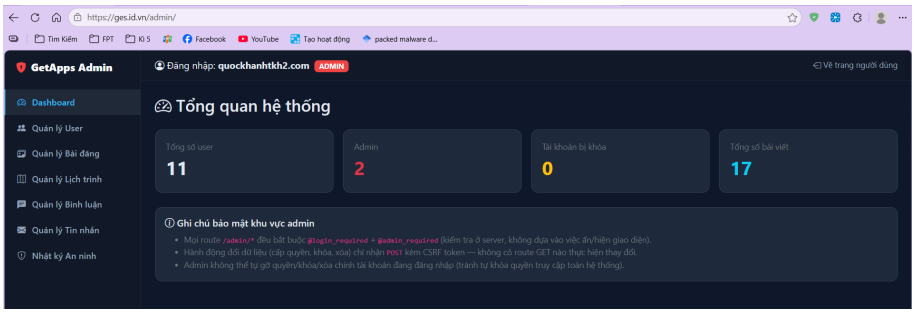
Trang quản trị (/admin, bảo vệ bằng decorator chỉ cho tài khoản có quyền admin truy cập) gồm các chức năng:

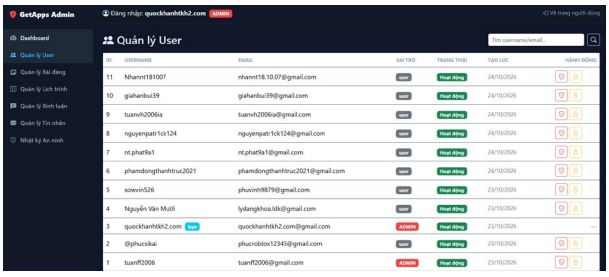
- Dashboard: tổng quan hệ thống.
- Quản lý Người dùng: khóa/mở khóa tài khoản, cấp/thu hồi quyền quản trị, xóa tài khoản.
- Quản lý Bài viết: ẩn/hiện, xóa, xem chi tiết từng bài (kèm file đính kèm nếu có).
- Quản lý Lịch trình: ẩn/hiện, xóa, xem chi tiết, tải file đính kèm lịch trình.
- Quản lý Bình luận: xem, xóa bình luận vi phạm.
- Quản lý Tin nhắn: xem cuộc trò chuyện, tải file đính kèm trong tin nhắn.
- Nhật ký An ninh (/admin/security-logs): xem và xóa nhật ký các sự kiện bảo mật (phục vụ demo).

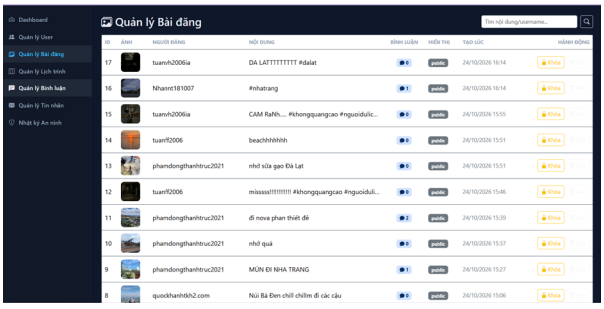
Khi admin ẩn hoặc xóa một bài viết/lịch trình nghi vi phạm, hệ thống tự gửi thông báo cho chủ bài biết (không trỏ tới nội dung đã ẩn/xóa, tránh truy cập lại nội dung đó).

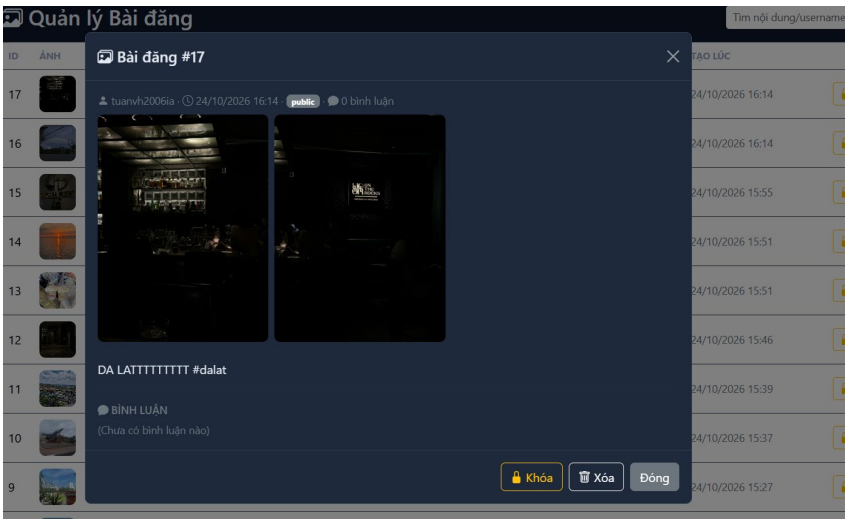
Kiểm chứng phân quyền (Broken Access Control)

Trên domain thật, truy cập /admin/users khi chưa đăng nhập trả về HTTP 401 — xác nhận cơ chế kiểm soát truy cập trang quản trị hoạt động đúng, người dùng thường hoặc khách không thể vào được khu vực quản trị.

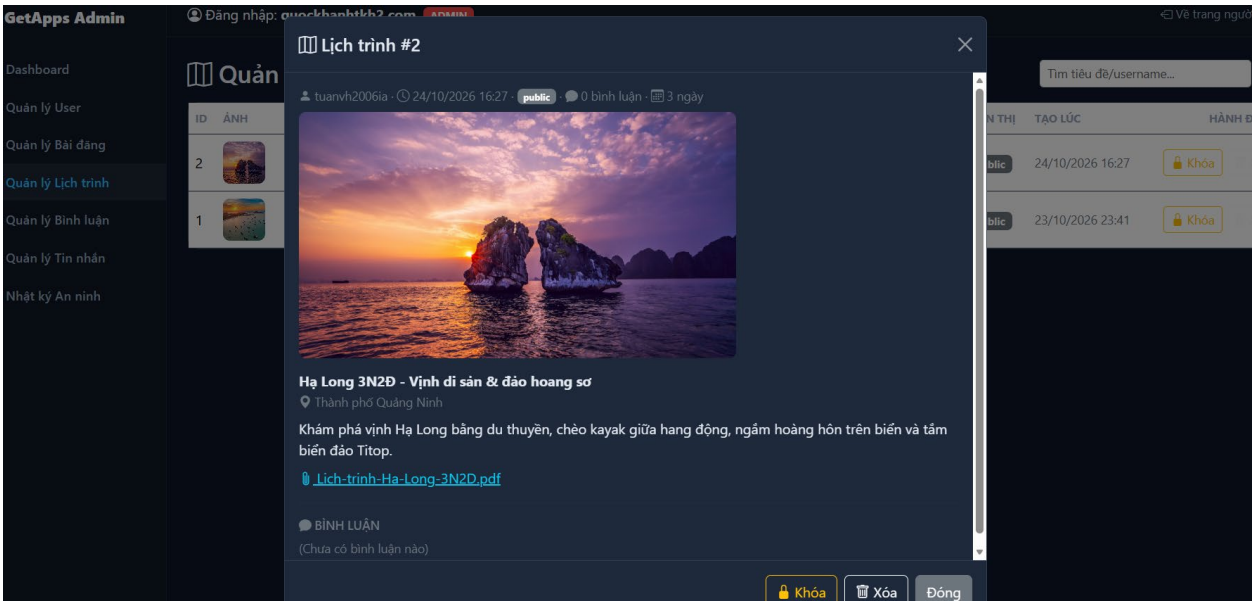


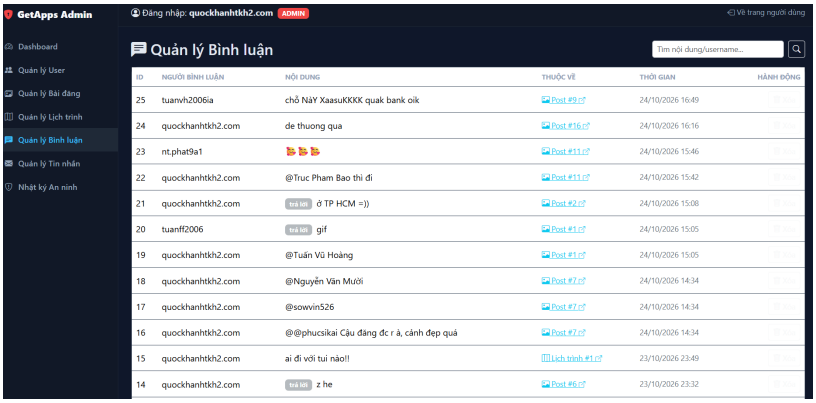


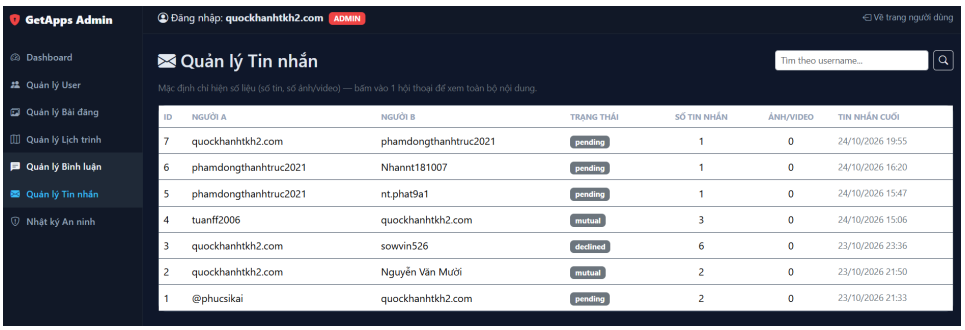


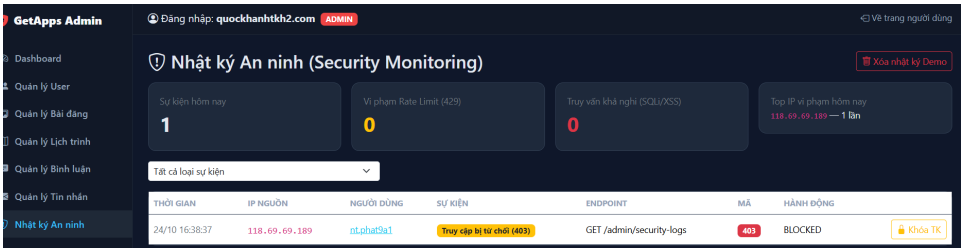

Quản lý Bài đăng
Tìm nội dung/username
Bài đăng #17
tuanvh2006ia · 24/10/2026 16:14 · public · 0 bình luận
DA LATTTTTTTTT #dalat
BÌNH LUẬN
(Chưa có bình luận nào)
Khóa
Xóa
Đóng


Dashboard
Quản lý User
Quản lý Bài đăng
Quản lý Lịch trình
Quản lý Bình luận
Quản lý Lịch trình
Tìm tiêu đề/username...
ID ẢNH NGƯỜI ĐĂNG TIÊU ĐỀ ĐIỂM ĐẾN BÌNH LUẬN HIỂN THỊ TẠO LÚC HÀNH ĐỘNG
2 tuanvh2006ia Hạ Long 3N2Đ - Vịnh di sản & đ... Thành phố Quảng Ninh 0 public 24/10/2026 16:27 Khóa
1 quockhanhtkh2.com Phan Thiết 2N1Đ - Du lịch và Ng... Tỉnh Lâm Đồng, Phường Phan Thiết 1 public 23/10/2026 23:41 Khóa


GetApps Admin
Đăng nhập: quockhanhtkh2.com ADMIN
Về trang người dùng
Dashboard
Quản lý User
Quản lý Bài đăng
Quản lý Lịch trình
Quản lý Bình luận
Quản lý Tin nhắn
Nhật ký An ninh
Lịch trình #2
tuanvh2006ia · 24/10/2026 16:27 · public · 0 bình luận · 3 ngày
Hạ Long 3N2Đ - Vịnh di sản & đảo hoang sơ
Thành phố Quảng Ninh
Khám phá vịnh Hạ Long bằng du thuyền, chèo kayak giữa hang động, ngắm hoàng hôn trên biển và tắm biển đảo Titop.
Lich-trinh-Ha-Long-3N2D.pdf
BÌNH LUẬN
(Chưa có bình luận nào)
Khóa
Xóa
Đóng


GetApps Admin
Đăng nhập: quockhanhtkh2.com ADMIN
Về trang người dùng
Quản lý Bình luận
Tìm nội dung/username...
ID NGƯỜI BÌNH LUẬN NỘI DUNG THUỘC VỀ THỜI GIAN HÀNH ĐỘNG
25 tuanvh2006ia chỗ NàY XaasuKKKK quak bank oik Post #9 24/10/2026 16:49
24 quockhanhtkh2.com de thuong qua Post #16 24/10/2026 16:16
23 nt.phat9a1 Post #11 24/10/2026 15:46
22 quockhanhtkh2.com @Truc Pham Bao thi đi Post #11 24/10/2026 15:42
21 quockhanhtkh2.com Trả lời ở TP HCM =)) Post #2 24/10/2026 15:08
20 tuanff2006 Trả lời gif Post #1 24/10/2026 15:05
19 quockhanhtkh2.com @Tuấn Vũ Hoàng Post #1 24/10/2026 15:05
18 quockhanhtkh2.com @Nguyễn Văn Mười Post #7 24/10/2026 14:34
17 quockhanhtkh2.com @sowvin526 Post #7 24/10/2026 14:34
16 quockhanhtkh2.com @@phucsikai Cậu đăng đc r à, cảnh đẹp quá Post #7 24/10/2026 14:34
15 quockhanhtkh2.com ai đi với tui nào!! Lịch trình #1 23/10/2026 23:49
14 quockhanhtkh2.com Trả lời z he Post #6 23/10/2026 23:32





13. Khai báo sử dụng AI

Trong quá trình thực hiện đồ án, nhóm có sử dụng công cụ AI (Claude của Anthropic) để hỗ trợ lập trình (sửa lỗi, triển khai hệ thống, viết kiểm thử) và hỗ trợ tổng hợp tài liệu cho báo cáo này từ các tài liệu, mã nguồn và kết quả kiểm thử do nhóm cung cấp.

14. Nguồn tham khảo và trích dẫn dữ liệu

- Dữ liệu địa danh hành chính 34 tỉnh/thành: vietnamese-provinces-database — https://github.com/thanglequoc/vietnamese-provinces-database (giấy phép MIT), cập nhật theo Nghị quyết 388/NQ-UBTVQH16.
- Dữ liệu địa điểm cho GEs Around: © OpenStreetMap contributors (giấy phép ODbL); Overture Maps Foundation.
- OWASP (Open Web Application Security Project) — khuyến nghị kiểm thử và phòng chống SQL Injection, XSS.
- Tài liệu chính thức các thư viện sử dụng: Flask, SQLAlchemy, Flask-Login, Flask-WTF, Flask-Migrate, Flask-Limiter (flask.palletsprojects.com và trang tài liệu riêng của từng thư viện).
- Tên miền miễn phí: chương trình đăng ký .id.vn.
- Hạ tầng máy chủ: VPS thuê tại nhà cung cấp zcloudviet, gói Cloud Standard (4 vCPU / 4GB RAM / 40GB SSD, Ubuntu 24.04).